

Clase 249 — Fundamentos de OSINT

Parte: **12 — OSINT e ingeniería social** · Fuente: *Open Source Intelligence Techniques* (M. Bazzell) · MITRE ATT&CK Reconnaissance 🕒 Duración estimada: **90 min** · Nivel: **Fundamentos**

Objetivo

Comprender qué es la inteligencia de fuentes abiertas, cómo se estructura el ciclo de inteligencia y cuáles son los límites éticos y legales que gobiernan toda recolección. Al terminar, el alumno sabrá plantear una operación OSINT metódica, trazable y defendible, distinguiendo entre "buscar en Google" y producir inteligencia útil a partir de datos públicos.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Definir** OSINT y diferenciarlo de HUMINT, SIGINT y otras disciplinas de inteligencia.
2. **Aplicar** el ciclo de inteligencia de cinco fases a un objetivo autorizado.
3. **Distinguir** OSINT pasivo de activo y sus implicaciones de detección y legalidad.
4. **Preparar** un entorno de investigación aislado con cuentas "sock puppet" y máquina desechable.
5. **Documentar** hallazgos con cadena de custodia y control de sesgos.

Temas

#	Tema	Por qué importa
1	Definición y disciplinas de inteligencia	Ubica OSINT en el mapa profesional
2	Ciclo de inteligencia (5 fases)	Convierte datos en inteligencia accionable
3	Pasivo vs. activo	Determina huella y riesgo legal
4	Fuentes abiertas: taxonomía	Saber dónde mirar antes de buscar
5	Entorno de investigación seguro	Evita contaminar y ser detectado
6	Sock puppets (identidades ficticias)	Separan al investigador del objetivo
7	Ética, legalidad y sesgos	Mantiene la operación lícita y objetiva
8	Documentación y trazabilidad	Hace el hallazgo verificable y reutilizable

Definiciones y características

- **OSINT (Open Source Intelligence):** inteligencia derivada de información **pública y de acceso legal**. Característica clave: la fuente es abierta, pero el valor está en la correlación, no en el dato aislado.
- **Ciclo de inteligencia:** proceso iterativo de *dirección* → *recolección* → *procesamiento* → *análisis* → *difusión*. Característica: es cíclico; el análisis genera nuevas preguntas.

- **OSINT pasivo:** recolección que no interactúa con la infraestructura del objetivo (cachés, buscadores, archivos). Característica: casi indetectable.
- **OSINT activo:** implica tocar sistemas del objetivo (visitar su web, resolver su DNS). Característica: deja rastros en logs.
- **Sock puppet:** identidad ficticia y creíble usada para investigar sin exponer al analista. Característica: debe tener historia y coherencia.
- **Cadena de custodia:** registro de cómo, cuándo y de dónde se obtuvo cada evidencia. Característica: sin ella, el hallazgo no es defendible.
- **Sesgo de confirmación:** tendencia a interpretar datos para confirmar una hipótesis previa. Característica: el principal enemigo del analista.

Herramientas y preparación

- **Máquina de investigación aislada:** VM (VirtualBox/VMware) con snapshot limpio, o la *Trace Labs OSINT VM* / Kali. Nunca investigues desde tu equipo y cuenta personales.
- **Navegador endurecido:** Firefox con contenedores (Multi-Account Containers), sin sesión personal; opcionalmente detrás de VPN/Tor según el alcance.
- **Gestor de casos:** herramienta para notas y capturas: Obsidian, CherryTree o una plantilla Markdown; captura con Hunchly si es un engagement formal.
- **OSINT Framework** (osintframework.com) como índice de fuentes por categoría.
- **Recordatorio:** todo se hace en entorno propio/aislado y sobre objetivos autorizados o públicos legítimos.

Laboratorio guiado

Ejercicio aplicado y **autorizado**: OSINT sobre ti mismo (autoevaluación de huella).

1. Crea un snapshot limpio de tu VM de investigación y anota fecha/hora de inicio del caso.
2. Define la **dirección**: escribe la pregunta de inteligencia (ej.: "¿qué datos míos son públicos y podrían usarse en un pretexto contra mí?").
3. **Recolección pasiva**: busca tu nombre entre comillas en varios buscadores (Google, Bing, DuckDuckGo) y en <https://www.google.com/search?q='Tu Nombre'>. Registra cada URL y captura.
4. Consulta motores especializados: <https://haveibeenpwned.com/> para brechas asociadas a tu correo.
5. Revisa metadatos de una foto tuya pública con [exiftool foto.jpg](#) y anota qué revela.
6. **Procesamiento**: vuelca los datos en una tabla (dato, fuente, fecha, confianza alta/media/baja).
7. **Análisis**: correlaciona; ¿qué combinación de datos permitiría suplantar te o adivinar respuestas de seguridad?
8. **Difusión**: redacta un mini-informe de 1 página con hallazgos y recomendaciones de reducción de huella.
9. Cierra el caso: exporta notas, restaura el snapshot y documenta lecciones aprendidas.

Ejercicios

1. Clasifica 10 fuentes de datos como pasivas o activas y justifica cada una.
2. Dibuja el ciclo de inteligencia y describe qué ocurre si se salta la fase de "dirección".
3. Crea un sock puppet coherente (nombre, correo dedicado, foto generada) y documenta su historia sin usarlo aún.

4. Redacta una hipótesis y luego lista 3 datos que la **refutarían**, para combatir el sesgo de confirmación.
5. Diseña la plantilla de tabla de hallazgos con columnas de confianza y verificación cruzada.
6. Investiga la diferencia entre OSINT y "doxing" y explica dónde está la frontera legal/ética.

Reto verificable

Produce un **informe OSINT de tu propia huella** (máx. 2 páginas) que incluya: pregunta de inteligencia, al menos 8 hallazgos con fuente y nivel de confianza, un diagrama de correlación y 5 recomendaciones concretas de reducción de exposición. **Criterio de aceptación:** cada hallazgo es reproducible por un tercero siguiendo la fuente citada, y el informe distingue explícitamente hechos verificados de inferencias.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
El objetivo detecta la investigación	Se hizo OSINT activo sin querer (visitar su web logueado). Usa fuentes pasivas y sock puppets.
Hallazgos que no se pueden reproducir	Faltó cadena de custodia. Registra URL, fecha y captura de cada dato.
Conclusiones sesgadas	Se buscó confirmar una hipótesis. Formula hipótesis rivales y busca refutarlas.
Cuenta personal filtrada al objetivo	Se usó el navegador/sesión propios. Investiga siempre desde la VM aislada.
Datos "públicos" pero de origen ilegal	Un leak robado no es fuente lícita. Verifica la legalidad de la fuente.

Preguntas frecuentes

? ¿OSINT es legal? Recolectar información genuinamente pública suele serlo, pero el uso, el almacenamiento de datos personales y la interacción con el objetivo tienen límites (GDPR, leyes locales). El contexto y el propósito determinan la legalidad.

? ¿Necesito Tor o VPN siempre? No siempre; depende del alcance y del riesgo de atribución. Para investigaciones sensibles, sí. Lo esencial es no exponer tu identidad real ni tocar la infraestructura del objetivo sin querer.

? ¿Un sock puppet es engañar? Es una identidad de investigación, no una suplantación de una persona real. No lo uses para acceder a sistemas privados ni para manipular a personas fuera de un engagement autorizado.

Referencias

- Bazzell, M. *Open Source Intelligence Techniques*. <https://inteltechniques.com/book1.html>
- MITRE ATT&CK — Reconnaissance (TA0043). <https://attack.mitre.org/tactics/TA0043/>
- OSINT Framework. <https://osintframework.com/>
- Trace Labs OSINT VM. <https://www.tracelabs.org/initiatives/osint-vm>

- Have I Been Pwned. <https://haveibeenpwned.com/>

Siguiente clase

Clase 250 - OSINT de personas